数据库原理

Database Principle

陶宏才，李晓航

西南交通大学

计算机与人工智能学院

第五章 数据库安全性

学习目的和要求

- 数据库保护概况
- 数据库与OS在安全上的关系
- 数据库安全性的目标
- 数据库的访问控制类型
- DAC访问控制的授/撤权
- SQL SERVER的安全体系结构
- 数据库安全其他内容：数据加密、审计、统计数据库安全等



5.1 数据库保护概况

一. 数据库破坏类型

① System Failure（系统故障）；

② Concurrency Execution引起数据不一致；

③人为破坏；

④对数据操作引入的数据错误。

二. 各种类型的保护措施

① System Failure —— 故障恢复；

② Concurrency Execution引起数据不一致 —— 并发控制；

③人为破坏 —— 数据库安全；

④对数据操作引入的数据错误 —— 数据库完整性。

5.2 数据库安全性概况

回答如下问题:

1.DBMS与OS在安全上的关系?

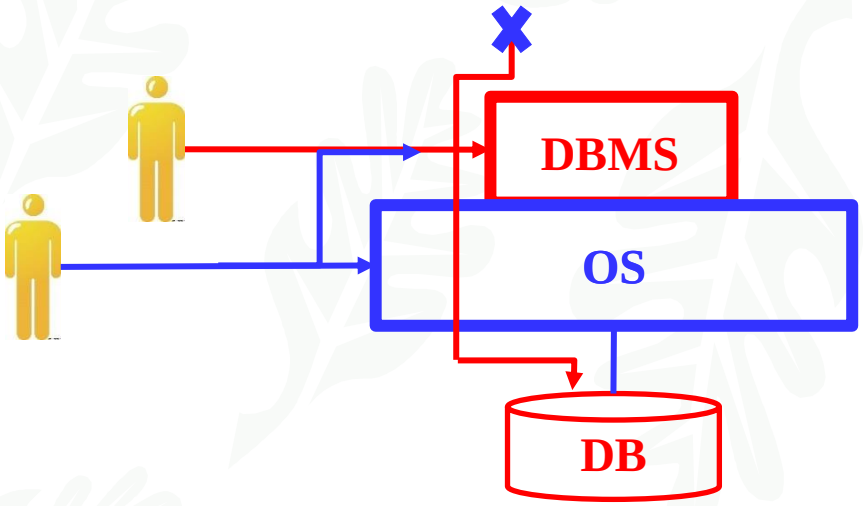
2.数据库安全性的目标?

3. DoD Security Levels ?

4.用户标识与鉴别?



一.DBMS与OS在安全上的关系



① 除了OS的安全屏障外，DBMS为加强其安全性，亦应建立有自己的安全体系；

② 由于DBMS建立在OS之上，要求OS提供承诺，即：不允许用户绕过DBMS安全体系而直接访问DB；

③ 正是因为DBMS和OS有各自独立的安全体系，因此OS的用户要想访问DBMS，必须由DBA设置成DBMS的用户。

二.数据库安全性的目标

① Secrecy（私密性）：指信息不能对未授权的用户公开；

② Integrity（完整性）：指只有授权用户才被允许修改数据；

③ Availability（可用性）：指授权用户不能被拒绝访问。

绝大多数商用RDBMS通过提供访问控制（Access Control）安全服务，来实现数据库的安全目标。

三. DoD Security Levels

1. 访问控制类型

（1）自主式访问控制DAC (Discretionary Access Control)：基于访问权限概念。SQL-92通过GRANT和REVOKE支持该DAC。

（2）强制访问控制MAC (Mandatory Access Control)：基于全系统范围策略，而不由某个用户改变。客体（Object，如：各种DB对象）和主体（Subject，如：用户、计算机、进程等）分别具有相应的安全级别(Security Class和Clearance)，如：绝密（Top-secret，TS）、机密（Secret，S）、秘密（Confidential，C）和无密级（Unclassified，U），主体只有在满足一定规则（如：下读——主体的安全级别必须高于所读客体的安全级别、上写——主体的安全级别必须低于所写入的客体的安全级别）才能访问某个客体。

MAC的4种组合规则：上读上写、上读下写、下读下写、下读上写。

（3）RBAC(Role-based Access Control)：基于角色访问控制，基本等价于DAC+角色（角色是权限的集合）。

标准支持情况：SQL-92不推荐MAC。目前商用RDBMS都支持RBAC。

2. 安全级别

现状：目前大多数RDBMS支持C2级DAC（国内）和B1级MAC（国外）。

安全级：分A、B、C和D四个等级，A最高，D最低。

C级：要求支持DAC，又分二个子级C1、C2。C2要求身份认证(Login verification)和审计跟踪(Audit Trails)。

B级：要求支持MAC，又分三个子级B1、B2、B3。

A级：要求有数学防范能力。

四.用户标识与鉴别

用户标识： 用户名。

用户鉴别：

① 只有用户知道的信息；

② 只有用户具有的物品；

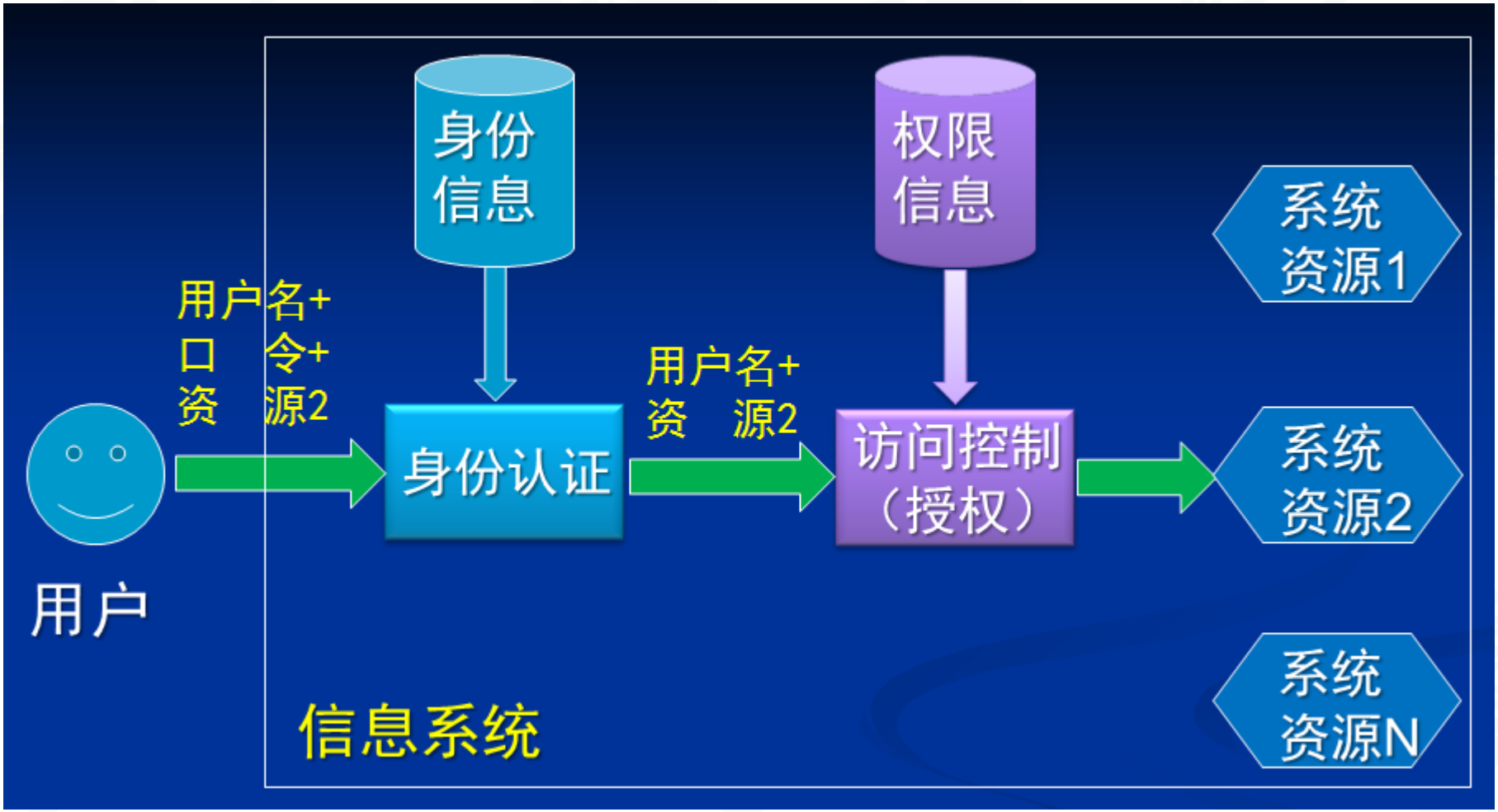
③ 个人特征。

最常见的用户鉴别： 口令，要求长度/时间长短/不回显、打印/不可逆加密保存。

用户鉴别和访问控制的关系：

用户认证（鉴别）：解决用户“是谁”的问题；

访问控制：解决用户“能做什么”的问题。



5.3 DAC访问控制的授/撤权

回答如下问题:

1.DAC的访问控制方式?

2.授权类型?

3.角色授/撤权?

4.数据库对象授/撤权?



一.DAC的访问控制方式

自主性访问控制是通过控制用户访问权限，即授权的方式进行的。

二.授权(Authorization)类型

(1)角色权限 —— 由DBA授予；

(2) DB对象权限 —— 由DBA或对象创建者授予。

三.角色授/撤权（Sql Server只支持Connect，且用处不大）

授权： GRANT <角色类型> [{, <角色类型>}] TO <用户>
[IDENTIFIED BY <口令>]

<角色类型>::=Connect|Resource|DBA

撤权： REVOKE <角色类型> [{, <角色类型>}] FROM <用户>

四.数据库对象授/撤权

授权： GRANT <权限> ON <表名> TO <受权者> [{, <受权者>}]
[WITH GRANT OPTION]

<权限>::=ALL PRIVILEGES | <操作> [{, <操作>}]

<操作>::=SELECT | INSERT | DELETE | UPDATE [(<列名表>)]

<列名表>::= <列名> [{, <列名>}]

<受权者>::=PUBLIC | <用户>

撤权： REVOKE <权限> ON <表名>
FROM <受权者> [{, <受权者>}]

WITH GRANT OPTION：指得到授权的用户，可以将其获得的权限转授给其他用户。

GRANT语句例子：

- GRANT SELECT ON TABLE Student To U1
- GRANT ALL PRIVILEGES ON TABLE Student, Course To U1, U2
- GRANT SELECT ON TABLE Student To Public
- GRANT UPDATE(Sname), SELECT ON TABLE Student To U1 WITH GRANT OPTION

5.4 SQL SERVER安全体系

讲解内容:

1.SQL SERVER安全体系结构

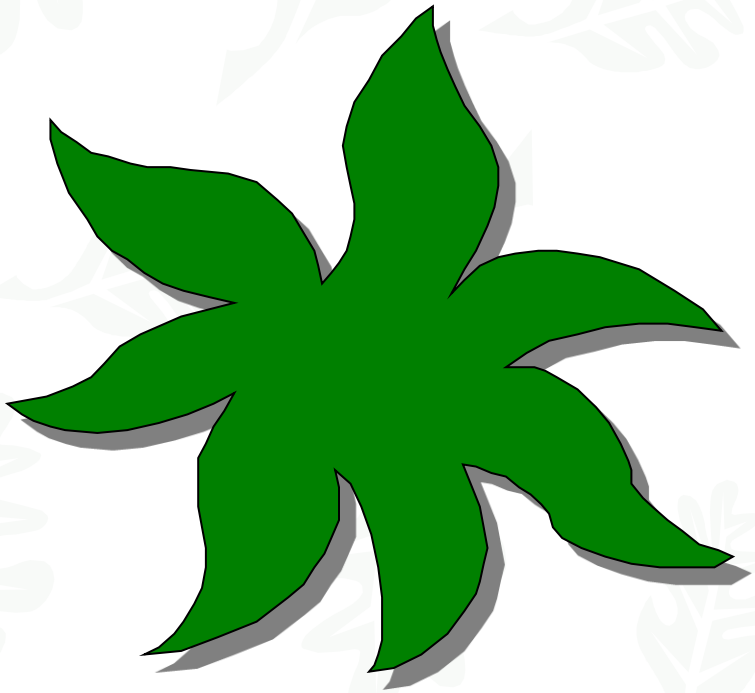
2.SQL SERVER登录用户

3.SQL SERVER角色定义

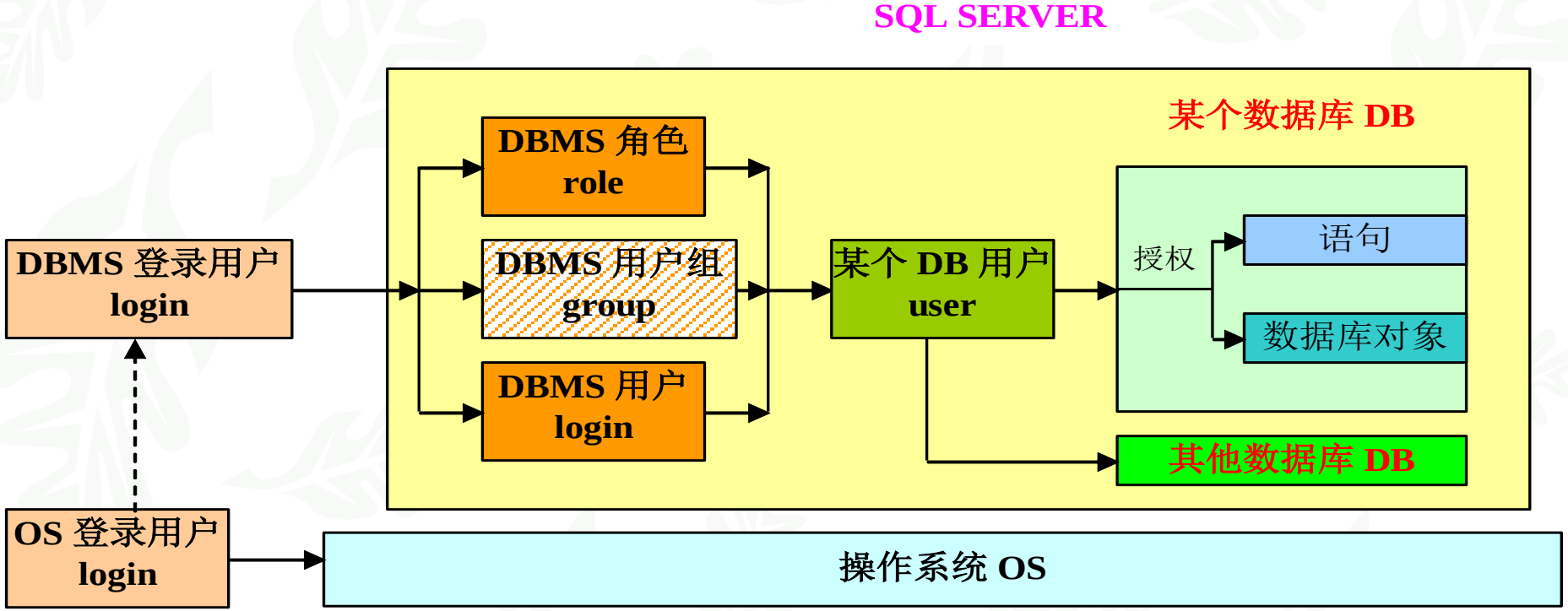
4.SQL SERVER数据库用户

5.SQL SERVER语句授权

6.SQL SERVER对象授权



一.SQL SERVER安全体系结构

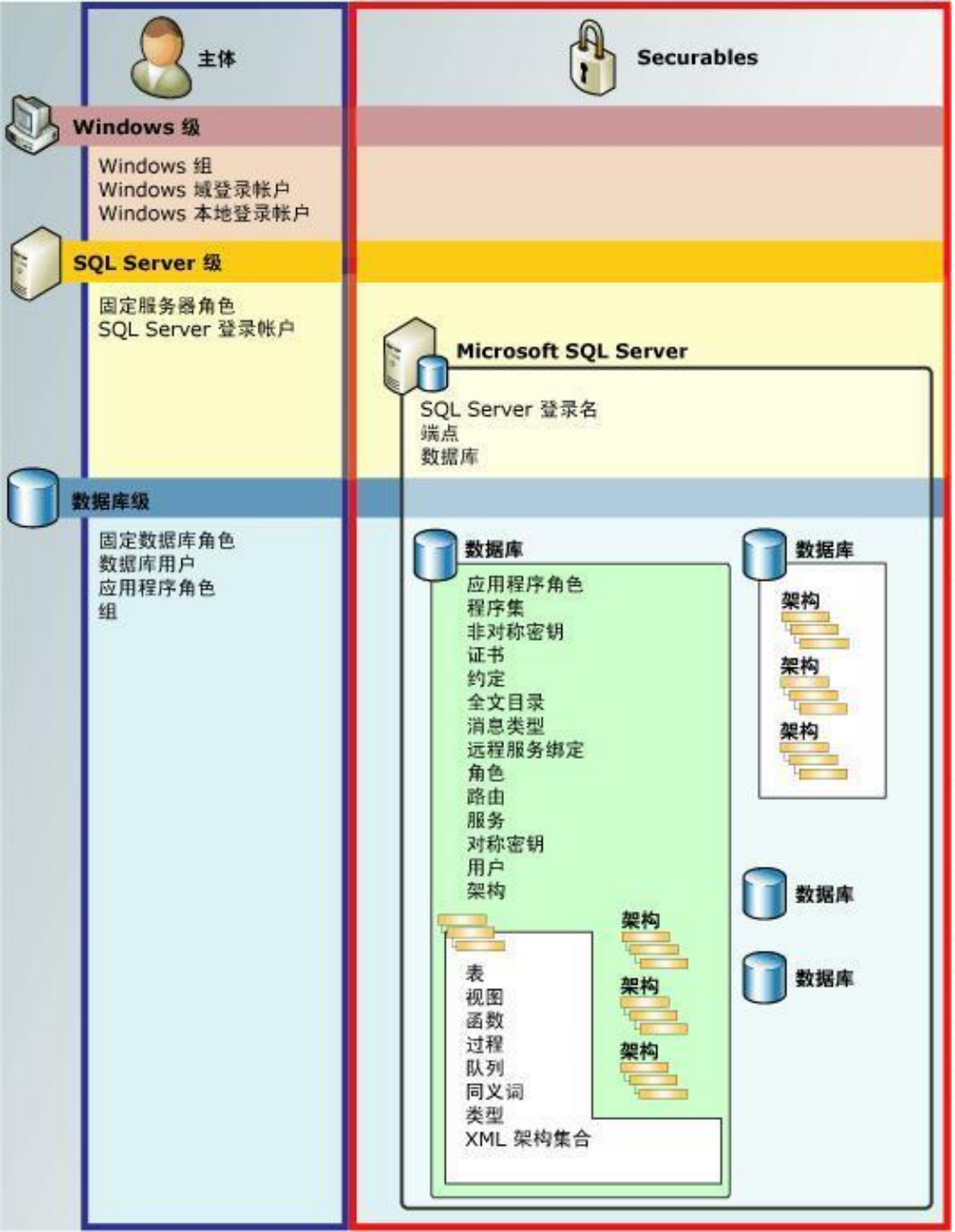


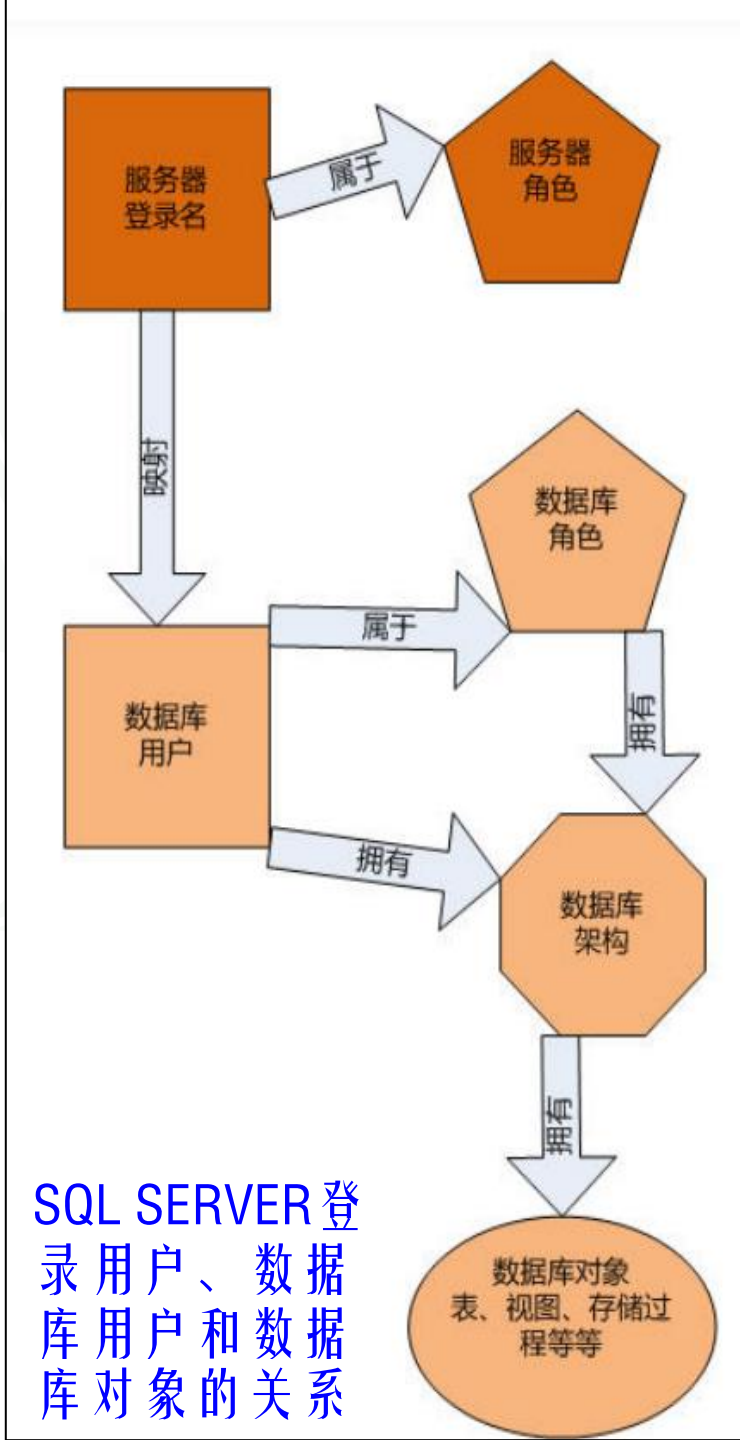
说明：

①“组”的概念只在7.0以前版本有。

② 登录名可以与DB用户名相同。登录用户只有在成为某个DB的用户时才能访问该DB。

③ 由上图可知，SQL SERVER安全体系由三级组成，即：DBMS或DB服务器、数据库（DB）级、语句与对象级。





SQL SERVER登录用户、数据库用户和数据库对象的关系

二. SQL SERVER登录用户

1. SQL SERVER设定的登录用户

(1) sa：系统管理员

2. 创建登录用户

创建登录用户存储过程（已弃用，现在用Create Login）：

```
sp_addlogin [ @loginame = ] '登录名'
            [ , [ @passwd = ] '口令' ]
            [ , [ @defdb = ] '缺省数据库名' ]
```

说明：

(1) 只有sa、sysadmin或securityadmin角色的成员才能执行sp_addlogin。

(2) 登录用户一旦创建即可连接DBMS。

(3) 相关的存储过程有：sp_grantlogin、sp_revokelogin、sp_droplogin、sp_password、sp_defaultdb等。

CREATE LOGIN：SQL Server 2005 及更高版本引入的 T-SQL 命令，用于创建服务器级登录名。

命令格式：

CREATE LOGIN login_name { WITH <option_list> | FROM <sources> }

<option_list> ::= PASSWORD = { 'password' | hashed_password HASHED } [MUST_CHANGE] [, ...]]

特性	CREATE LOGIN	sp_addlogin
推荐程度	✓ 推荐（SQL Server 2005+）	✗ 已弃用（仅旧版本兼容）
密码策略支持	✓ 支持 CHECK_POLICY	✗ 不支持
密码过期支持	✓ 支持 CHECK_EXPIRATION	✗ 不支持
SID 控制	✓ 可选指定 SID	✗ 需要额外参数
加密选项	✓ 自动处理	✗ 需要手动指定 @encryptopt
适用版本	SQL Server 2005+	SQL Server 2000 及更早

三.SQL SERVER角色定义

1. SQL SERVER中的系统角色

(1) 服务器级的系统角色

sysadmin 、 securityadmin 、 serveradmin 、 setupadmin 、 processadmin、diskadmin、dbcreator、bulkadmin

(2) 常用的数据库级系统角色

public、dbo

说明：

① 以上系统角色的权限是固定的。

② sa被自动分配为sysadmin角色。

③ 数据库的用户自动分配为public角色。

④ 创建数据库对象的用户自动分配为该对象的dbo角色。

2. 数据库（用户）角色的创建

sp_addrole [@rolename =] '新角色名'

[, [@ownername =] '该角色所有者'] （已弃用）

为角色增加成员用户：sp_addrolemember（已弃用）

删除角色：sp_droprole

查询角色信息：sp_helprole

现在应该采用 CREATE ROLE 语句

CREATE ROLE：在当前数据库中创建新的数据库角色。

命令格式：

CREATE ROLE role_name [AUTHORIZATION owner_name]

四.SQL SERVER数据库用户

1. SQL SERVER设定的缺省数据库用户

guest：一个登录用户在被设定为某个数据库用户之前，可用guest用户身份访问该数据库。

2. 授权登录用户访问某个数据库

sp_adduser [@loginame =] '登录名'

[, [@name_in_db =] '访问数据库时用的名字']（已弃用）

删除数据库用户：sp_dropuser

查询数据库用户信息：sp_helpuser

其他相关存储过程：sp_grantdbaccess、sp_revokedbaccess。

现在应该采用 CREATE USER 语句创建数据库用户

CREATE USER：向当前数据库添加用户。

命令格式：

```
CREATE USER user_name
   [ { { FOR | FROM }
      { LOGIN login_name
      | CERTIFICATE cert_name
      | ASYMMETRIC KEY asym_key_name
      }
     | WITHOUT LOGIN
   ]
   [ WITH DEFAULT_SCHEMA = schema_name ]
```

ALTER ROLE：现在采用的为角色增/删成员用户的语句

命令格式：

ALTER ROLE role_name

{ ADD MEMBER database_principal | DROP MEMBER database_principal }

特性	sp_addrolemember	ALTER ROLE
推荐程度	✗ 已弃用	✓ 推荐
SQL 标准兼容性	✗ 专有语法	✓ 符合标准
功能完整性	✓ 只能添加	✓ 可添加/删除
错误处理	✗ 较差	✓ 更好
未来支持	✗ 可能移除	✓ 长期支持
参数灵活性	✗ 较少选项	✓ 更灵活
角色嵌套	✓ 支持（但不推荐）	✗ 不支持直接嵌套
文档状态	✗ 已标记弃用	✓ 官方推荐

五.SQL SERVER语句授权

授权语法：

GRANT{ALL | 语句[,...n]} TO <数据库角色或用户>[,...n]

可被授权的语句：

CREATE DATABASE、CREATE DEFAULT、CREATE FUNCTION、CREATE PROCEDURE、CREATE RULE、CREATE TABLE、CREATE VIEW、BACKUP DATABASE、BACKUP LOG。

语句授权功能：授权创建/管理数据库对象（CREATE类）



六.SQL SERVER对象授权

授权语法：

```
GRANT { ALL [ PRIVILEGES ] | 权限 [ ,...n ] }
        {
            [ ( 列名 [ ,...n ] ) ] ON { 表名 | 视图名 }
          | ON { 表名 | 视图名 } [ ( 列名 [ ,...n ] ) ]
          | ON { 存储过程 }
        }
        TO { 用户 | 角色 } [ ,...n ]
        [ WITH GRANT OPTION ]
        [ AS { 角色 } ]
```

说明：

(1) WITH GRANT OPTION选项只能授给用户，不能授给角色。得到该选项的用户可将所被授予的权限转授给其它用户；

(2) AS用于将权限授给角色。

注意：不同的数据库对象有不同的权限。

表、视图的权限：SELECT, INSERT, DELETE, UPDATE, REFERENCES.

列的权限：SELECT and UPDATE.

存储过程的权限：EXECUTE.

对象授权功能：授权对已有对象进行增删改查（SELECT/INSERT/UPDATE/DELETE 等）



5.4 数据库安全其他相关内容

讲解内容:

1. 数 据 加 密
2. 审 计 跟 踪
3. 统 计 数 据 库 的 安 全



一.数据加密（Data Encryption）

数据加密场合：存储/传输二个环节。

加密的基本思想：加密/解密算法(En/De–cryption Algorithm) + 加密/解密密钥(En/De–cryption Key)。

$$m = D_{k_d}(E_{k_e}(m))$$

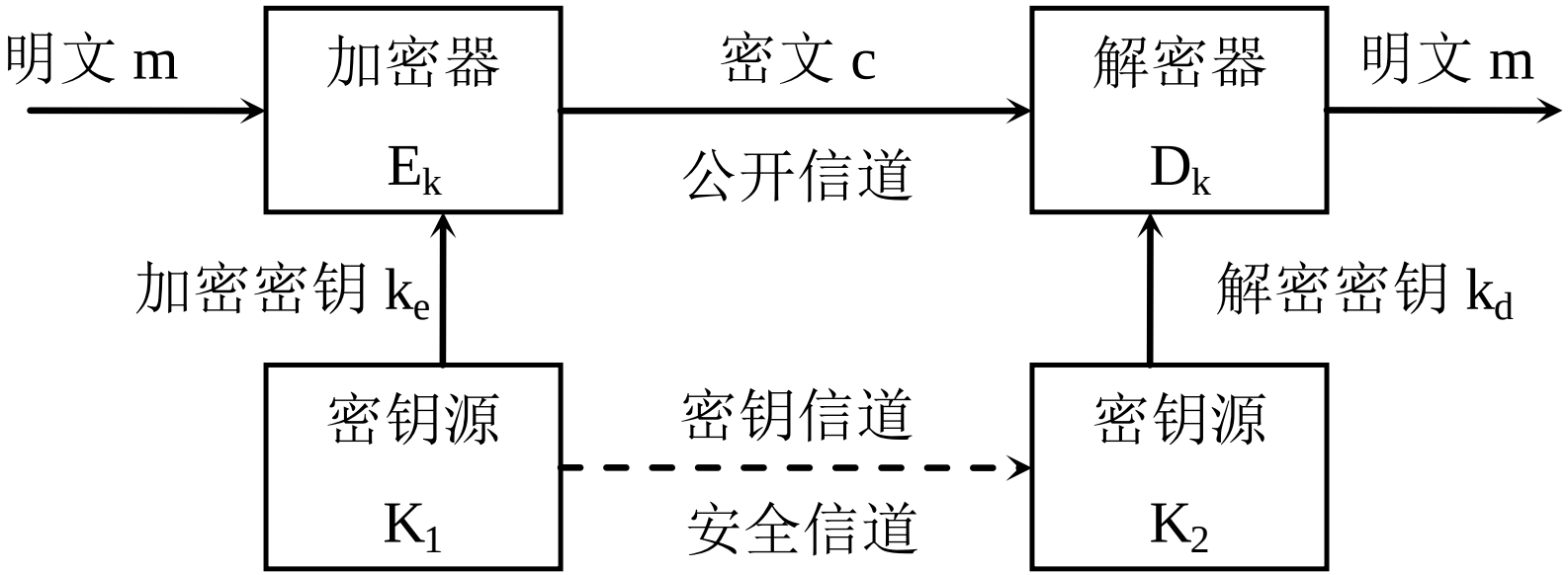


图 5-2 密码体制模型

(1) 对称加密（私钥加密）

基本原理：利用变换/替换/置换等方法完成加密/解密，加密密钥与解密密钥相同。

优点：速度快。

缺点：接收方须被告知密钥——密钥分发困难。

典型代表：DES (Data Encryption Standard)，1977年使用，密钥长度56位。事例：1997年DES挑战。

其他对称加密算法：

- ✓ IDEA（International Data Encryption Algorithm）
- ✓ AES（Advanced Encryption Standard）
- ✓ 3DES
- ✓ 以及RC2、RC4、RC5、Blowfish 等等。

(2) 非对称加密（公钥加密, Public-Key Encryption）

基本思想：利用数学难题（如大数分解、对数求解、离散对数等）建立，公钥(公开、加密)和私钥(私有、解密)不相同。

优点：易于密钥分发。

缺点：速度慢。

典型代表：RSA，由Rivest, Shamir, and Adleman提出。

RSA的重要特征：算法可逆，即先加密后解密，或先解密后加密，都可以复原原始数据。应用事例：数字签名。

$$m = D_{k_d}(E_{k_e}(m)) = E_{k_e}(D_{k_d}(m))$$

其它非对称加密体制：

- ✓ D–H（Diffie–Hellman）体制
- ✓ ElGamal体制
- ✓ ECC（Elliptic Curve Cryptography）体制 等等。

我国王小云院士最有影响的破解：

- ✓ MD5 （ Message Digest 5 ）
- ✓ SHA–1（Secure Hash Algorithms –1 ）

二.审计跟踪（Audit Trail）

作用：一种监视机制，由DBA控制。对被保密数据的访问进行跟踪，一旦发现潜在企图即报警或事后分析。

跟踪的记录内容：

① 操作类型；

② 主机和用户标识；

③ 日期时间；

④ 操作的数据；

⑤ 数据的前后值。

使用： 具体的DBMS一般提供相应命令设置/撤销跟踪。

三.统计数据库安全

统计DB：存有个人或事件特别信息，且只允许作统计查询而不允许作个别查询的DB。

防范：由于个人信息可能从允许查询的结果中推测出，应该堵住此暗道(Covert Channel)。

阻止方法：

① 最小行数N限制；

② 最大交M限制；

③ 查询总数限制。

现状：统计DB上的安全难以实施。



—— The End ——